

VirtuEx 시스템 감사 보고서 (4차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 4차 감사 작성일: 2026-03-02 작성: 시스템 감사팀

1. 개요

4차 감사는 1~3차 감사에서 수정 완료된 86건 이후 신규 발견된 이슈를 대상으로 합니다. 백엔드 8개 서비스, 프론트엔드(Next.js 15), 인프라(Docker/Kafka/모니터링), 빌드/환경 설정 전체를 정밀 점검하여 총 **79건**의 신규 이슈를 식별했습니다.

1.1 감사 범위

영역	발견 이슈
보안 (백엔드 + 인프라 + 프론트엔드)	12건
데이터 무결성	8건
성능	7건
코드 품질 — 백엔드	7건
인프라/빌드/환경	24건
프론트엔드 코드 품질	5건
프론트엔드 i18n	9건
프론트엔드 접근성	3건
프론트엔드 상태/UX	4건
합계	79건

2. 보안 감사 (12건)

#	항목	위험도	상태
1	Settings 프록시 전체 헤더 전달	상	✓
2	페이지뷰 path 미검증 (무인증)	상	✓
3	환경 파일 Git 추적	상	✓
4	시드 파일 개인정보 하드코딩	상	✓
5	accessToken localStorage 저장	상	✓
6	viewCount 무인증 무제한 증가	중	✓
7	Email 에러 로그 이메일 노출	중	✓
8	ThrottlerModule 하드코딩	중	✓
9	refreshAlerts 빈 catch 블록	중	✓

10	채팅방 join-room 권한 미검증	중	✓
11	page-view 프록시 미인증	중	✓
12	Next.js 보안 헤더 불완전	중	✓

상세 (상 위험도)

#1 `headers: req.headers` 로 클라이언트 전체 HTTP 헤더를 내부 서비스에 전달. Host, Content-Length 등 위험 헤더 포함 → 헤더 인젝션 위험. 수정: 필요한 헤더만 명시적 전달

#2 `POST /statistics/page-view` 에서 `body.path` 를 검증 없이 DB 저장. 인증 불필요 → DB 소진 DoS 위험. 수정: 길이 제한(500자) + 형식 검증 + 속도 제한

#3 `.env.development/.staging/.production` 이 Git에 추가됨. 개발용 시크릿·호스트명 노출. 수정: `.gitignore` 에 추가 후 `git rm --cached` 실행

#4 `seed.ts` 에 실제 비밀번호(`ehgm15516!`), 주민등록번호(`9311171052812`), 전화번호, 실명, 주소 하드코딩. 수정: 환경변수 또는 가상 데이터로 교체

#5 Zustand `persist` 의 `partialize` 에서 `accessToken` 을 `localStorage`에 저장 → XSS 시 탈취 위험. 수정: `partialize` 에서 `accessToken` 제거, 메모리만 유지

3. 데이터 무결성 (8건)

#	항목	위험도	상태
13	marketDataUrl 기본값 오류 (3003→3001)	상	✓
14	Settings bulkUpdate 트랜잭션 미적용	중	✓
15	getUserOrders any 타입	중	✓
16	announcement 댓글 매핑 any 타입	중	✓
17	withRetry any 타입	중	✓
18	toBalanceInfo/toHoldingInfo any 타입	중	✓
19	\$executeRawUnsafe 사용	중	✓
20	statistics period 파라미터 미검증	하	✓

#13 (상) `MARKET_DATA_URL` 기본값이 `http://localhost:3003` (portfolio 자신의 포트). market-data는 3001번 포트 → 자기 참조 무한 루프. 수정: 기본값을 `http://localhost:3001` 로 변경

4. 성능 감사 (7건)

#	항목	위험도	상태
21	getTradingStats 전체 주문 메모리 로드	상	✓
22	statistics 대량 레코드 메모리 로드	상	✓

23	aggregateHigherIntervals N+1 쿼리	중	✓
24	fetchMarketPrices 내부 토큰 미전달	중	✓
25	채팅 통계 raw SQL bigint 캐스팅	하	✓
26	leaderboard fetch more 비효율	중	✓
27	scrapeAll isScraping 플래그 누락	하	✓

#21 (상) getTradingStats(days) 메서드가 모든 주문을 findMany 로 메모리 로드 후 JS에서 집계 → OOM 위험. 수정: Prisma groupBy + _sum / _count DB 집계

#22 (상) registrationStats, loginStats 등에서 days 파라미터 상한 없이 전체 레코드 로드 → ? days=99999 시 전체 테이블 로드. 수정: days 상한(365) + DB 집계

5. 코드 품질 — 백엔드 (7건)

#	항목	위험도	상태
28	validateHoldings any 타입	중	✓
29	reserveFunds any 타입	중	✓
30	인메모리 오더북 복구 불가	중	✓
31	Announcement 알림 실패 무시	하	✓
32	news 개별 아이템 빈 catch	하	✓
33	TOTP 브루트포스 방지 없음	중	✓
34	chat deleteRoom 트랜잭션 미적용	중	✓

#30 매칭 엔진 오더북이 순수 인메모리(Map). 서비스 재시작 시 PENDING 지정가 주문 복원 안 됨. 수정: onModuleInit 에서 PENDING 주문 DB 로드

#33 TOTP 6자리(100만 가지), window: 1 로 2개 유효 → 자동화 브루트포스 ~50만회 내 성공. 수정: Redis 기반 시도 횟수 제한(5회 실패 시 5분 잠금)

6. 인프라/빌드/환경 (24건)

6.1 Docker (5건)

#	항목	위험도	상태
35	docker-compose 레거시 version 키	하	✓
36	Redis 인증 미적용	중	✓
37	모니터링 헬스체크 미설정	중	✓
38	모니터링 리소스 제한 미설정	중	✓

39	PostgreSQL healthcheck 환경변수 미참조	하	✓
----	---------------------------------	---	---

6.2 빌드 설정 (5건)

#	항목	위험도	상태
40	NestJS 보조 패키지 버전 불일치	중	✓
41	class-validator 버전 불일치	하	✓
42	@prisma/client 버전 불일치	하	✓
43	chat Prisma DB 스크립트 누락	하	✓
44	turbo.json Prisma generated 미포함	중	✓

6.3 데이터베이스 (3건)

#	항목	위험도	상태
45	데이터 보존 정책 부재	중	✓
46	Event Store Outbox 정리 정책 부재	중	✓
47	Transaction type enum 미적용	하	✓

6.4 환경변수 (5건)

#	항목	위험도	상태
48	.env.example에 CORS_ORIGIN 누락	중	✓
49	.env.example에 MARKET/PORTFOLIO URL 누락	중	✓
50	.env.example에 GRAFANA_ADMIN_USER 누락	하	✓
51	환경별 인증 설정 누락	중	✓
52	.env에 개인 연락처 하드코딩	하	✓

6.5 스크립트 (4건)

#	항목	위험도	상태
53	Kafka 토픽명 불일치	상	✓
54	backup-db.sh 단일 DB만 백업	중	✓
55	스크립트 프로젝트 경로 오류	하	✓
56	BigInt.prototype.toJSON 미제거	중	✓

6.6 모니터링 (2건)

#	항목	위험도	상태
---	----	-----	----

57	Prometheus 알림 규칙 미설정	중	✓
58	Grafana 데이터 소스 프로비저닝 미설정	하	✓

#53 (상) start-all.sh 에서 생성하는 Kafka 토픽명(price.updated , order.events , trade.events)이 실제 코드(market.prices.updated , orders.events , trades.executed)와 불일치.

KAFKA_AUTO_CREATE_TOPICS_ENABLE=false → 메시지 발행/소비 실패. 수정: 실제 토픽명으로 수정

7. 프론트엔드 감사 (21건)

7.1 코드 품질 (5건)

#	항목	위험도	상태
59	useLeaderboard any [] 타입 사용	중	✓
60	로그인 user: any 타입	중	✓
61	대시보드 as any [] 캐스팅	중	✓
62	Recharts label any 타입	하	✓
63	PageViewTracker eslint-disable	하	✓

7.2 i18n — 국제화 (9건)

#	항목	위험도	상태
64	ChatPanel 나가기 확인 한국어 하드코딩	중	✓
65	MessageArea '(me)' 영어 하드코딩	하	✓
66	MessageArea 'Kick' 영어 하드코딩	하	✓
67	useChat 전송 실패 한국어 하드코딩	중	✓
68	AIInsights 에러 한국어 하드코딩	중	✓
69	MobileMenuButton aria 한국어 하드코딩	중	✓
70	관리자 설정 실패 한국어 하드코딩	중	✓
71	마이페이지 알림 실패 한국어 하드코딩	중	✓
72	OrderBook 'No data' 영어 하드코딩	하	✓

7.3 접근성 (3건)

#	항목	위험도	상태
73	OrderSheet role="dialog" 누락	중	✓
74	SpotlightSearch role="dialog" 누락	중	✓
75	비밀번호 모달 ARIA/포커스 트랩 미적용	중	✓

7.4 상태 관리 / UX (4건)

#	항목	위험도	상태
76	MessageArea eslint-disable	하	✓
77	공지사항 eslint-disable	하	✓
78	PinnedChatPanel 나가기 확인 없음	중	✓
79	PhoneVerification 영어 하드코딩	중	✓

8. 종합 평가

8.1 위험도별 분류

위험도	건수
상	8
중	48
하	23
합계	79

- 상 (8건): #1, #2, #3, #4, #5, #13, #21, #22, #53
- 중 (48건): #6-#12, #14-#19, #23-#24, #26, #28-#30, #33-#34, #36-#38, #40, #44-#46, #48-#49, #51, #54, #56-#57, #59-#61, #64, #67-#71, #73-#75, #78-#79
- 하 (23건): #20, #25, #27, #31-#32, #35, #39, #41-#43, #47, #50, #52, #55, #58, #62-#63, #65-#66, #72, #76-#77

8.2 우선순위 권고

즉시 수정 (상 위험도 8건):

1. #3 환경 파일 Git 추적 해제 + #4 시드 개인정보 제거
2. #13 MARKET_DATA_URL 기본값 3003→3001
3. #1 Settings 프록시 헤더 + #2 페이지뷰 path 검증
4. #5 accessToken localStorage 제거
5. #53 Kafka 토픽명 수정
6. #21, #22 대량 데이터 메모리 로드 → DB 집계

단기 수정 (중 위험도 48건):

- 보안: #6, #7, #8, #10, #11, #12, #33, #36
- 타입 안전성: #15-#18, #28-#29, #59-#61
- 트랜잭션/무결성: #14, #19, #34
- 인프라: #37-#38, #40, #44-#46, #48-#49, #51, #54, #56-#57
- i18n: #64, #67-#71
- 접근성: #73-#75
- UX: #78-#79

8.3 영역별 성숙도

항목	점수 (5점)	비고
보안	3.0/5	환경파일 추적, 시드 PII, localStorage 토큰, 미인증 엔드포인트
데이터 무결성	3.5/5	any 타입 다수, 트랜잭션 미적용
성능	3.5/5	메모리 로드 패턴, N+1 쿼리
인프라	3.5/5	Kafka 불일치, 모니터링 헬스체크, Redis 인증
빌드/환경	3.5/5	NestJS 버전 불일치, 환경변수 누락
프론트엔드 코드	3.5/5	any 타입, eslint-disable 잔존
i18n	3.0/5	9건 하드코딩 잔존
접근성	3.5/5	모달 ARIA 누락 3건
종합	3.3/5	

8.4 1~3차 대비 현황

차수	발견	수정	스킵	미수정
1차	36	36	0	0
2차	50	45	4	1
3차	0 (검증)	-	-	-
4차	79	79	0	0

본 보고서는 VirtuEx 시스템의 4차 감사 결과이며, 1~3차 감사에서 수정된 이슈는 포함하지 않습니다. 2026-03-02 기준 소스 코드를 대상으로 합니다.